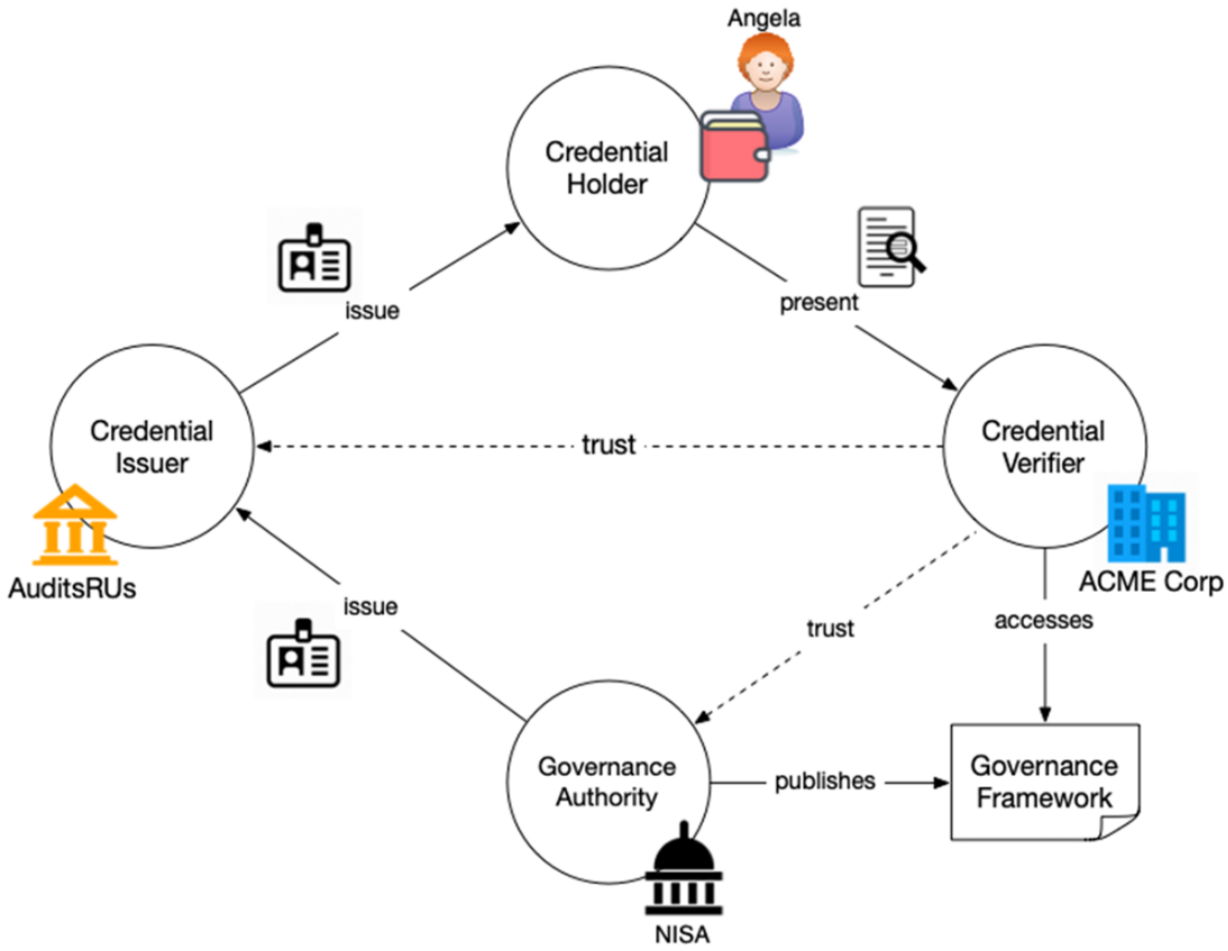


Figure 16.2 The trust diamond. The governance authority (NISA) establishes the rules for issuing and verifying security-auditor credentials. NISA grants an accreditation credential to AuditsRUs and publishes a governance framework. ACME consults that framework to decide which issuers it should trust and for which purposes. The verifier's trust in the issuer is based on the governance authority's rules, not in the credential holder.

Establishing trust in issuers is a core part of ACME's internal governance. Before a credential is used in policy evaluation, someone within ACME must verify that the issuer is trusted for the claims it makes. This verification happens before presentation, as part of the identity team's ongoing management of external vendors.

16.3.1 Example: ACME onboards AuditsRUs as a trusted issuer

Several months before Angela's audit, ACME's security auditing team began evaluating potential external audit firms. Tim, a senior member of ACME's security team, was tasked with deciding whether AuditsRUs should be added